CYBERSECURITY · DIGITAL FRAUD

SCAN BEFORE YOU TRUST



The Small Business Guide to **QR Code Scams**, **Safe Payments** and **Customer Protection**

FAKE STICKERS · SAFE PAYMENTS · WI-FI AND BOOKING · CUSTOMER TRUST

ZIRLANDIA MILKOVIC

CYBERSECURITY · DIGITAL FRAUD

SCAN BEFORE YOU TRUST

The Small Business Guide to QR Code Scams, Safe Payments and Customer Protection

ZIRLANDIA MILKOVIC

Scan Before You Trust

The Small Business Guide to QR Code Scams, Safe Payments and Customer Protection

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced without written permission, except for brief quotations in reviews.

First edition, 2026. Research cut-off: 11 November 2026. British English. Companion resource: GDPRGard.eu.

This book is practical guidance, not legal, security or data-protection advice. All examples, businesses and people in worked scenarios are fictional.

Contents

START HERE

Educational Disclaimer 4
Introduction: The Sticker on the Table 4
Who This Book Is For 5
How to Use This Book 6
The Ten-Minute QR Exposure Check 7

CHAPTERS

1. Why QR Codes Are Everywhere, and Why Criminals Like Them 8
2. Anatomy of a QR Code 11
3. The Sticker Over the Real Code 14
4. Fake Menus and Fake Payment Pages 17
5. QR Codes in Emails and PDFs 20
6. Fake Invoices and Supplier Requests 23
7. Hotels, Venues and Events 26
8. Protecting Your Wi-Fi and Booking Codes 29
9. How to Inspect a QR Code Before You Display It 32
10. Securing the Codes You Display 35
11. Safe Payments: Setting Up QR Payments So Problems Show Up Fast 38
12. Protecting Your Customers 41
13. When It Goes Wrong: The First Hour 44

CLOSING

Conclusion: Scan Before You Trust 47

APPENDICES

Appendix A: QR Code Inventory 48
Appendix B: The Weekly Check Log 49
Appendix C: One-Page Staff Briefing 50
Appendix D: Wording for Signs and Messages 51
Appendix E: Incident Response Checklist 52
Appendix F: Questions for a QR Code Provider 54

BACK MATTER

Glossary 55
A Note on GDPRGard.eu 56
About the Author 57
Notes and Sources 58

Educational Disclaimer

This book is practical, educational guidance for small-business owners, venue and event teams, freelancers and the people who support them. It is not legal, financial, security-engineering or payment-compliance advice, and it does not create a professional relationship between the author and the reader.

Scam techniques, payment products, app menus and the law change quickly. Menu names and options differ between products and move over time. Before relying on anything here for a decision that matters, check the current guidance of your bank or payment provider, your national cyber-security agency and your data-protection authority, or ask a qualified adviser.

Following the steps in this book can make it much harder for a criminal to tamper with the QR codes you display or to abuse your customers' trust in them. It cannot make it impossible, and no tool or checklist can promise that.

Every business, person and incident in a worked example is **fictional** and labelled as such. Real reports, statistics and official warnings are sourced in the notes at the back. Web addresses in the book are written in a defanged style where they illustrate a scam, so that nothing here can be clicked by accident.

Introduction: The Sticker on the Table

A café owner we will call Nadia prints a small sign for every table: *Scan to see our menu and pay.* It has worked well for two years. Customers like it, the staff like it, and the code on each sign leads to a tidy page with her logo.

One Saturday a regular mentions, half joking, that the payment page "looked a bit different" last week. Nadia checks. On four of her eleven tables, a slightly glossy sticker has been placed exactly over her code. It

is the same size, the same black and white. Anyone who scanned it would have landed on a page that looked almost like hers, and that sent the money somewhere else.

Nothing was hacked. No password was guessed. Someone walked in, bought a coffee, and spent ten seconds with a roll of stickers.

That is the whole point of this book. **A QR code is a printed instruction that nobody can read.** Your customers cannot tell, by looking at it, whether it leads to your menu, a copy of your menu, or a page built to take their card details. They scan it because they trust the place where it is displayed. Criminals have noticed, and they are exploiting that trust in three places at once:

- **On your premises,** where a sticker is pasted over a real code.
- **In your inbox,** where invoices, "document" PDFs and booking messages arrive with a QR code instead of a link.
- **In your customers' hands,** where a fake menu, fake payment page or fake Wi-Fi sign borrows your name.

This book explains how each of these works, in plain language, and then spends most of its pages on what you can do: inspect the codes you display, place and print them so they are hard to tamper with, set up payments so a diverted code is noticed within minutes, protect your Wi-Fi and booking codes, tell customers how to recognise the real thing, and respond quickly if something goes wrong.

You will not be asked to stop using QR codes. They are cheap, fast and genuinely useful, and customers expect them. The goal is smaller and more achievable: **codes you can stand behind.**

> **The rule.** Treat every QR code as a link someone else chose. Before you display one, scan one, or ask a customer to scan one, ask: who made this, who could have changed it, and how would I know?

Who This Book Is For

This book is written for people who display QR codes, receive them, or both:

- **Restaurant, café and bar owners** with table-menu and pay-at-table codes.
- **Hotels, guesthouses and holiday-let hosts** with check-in, booking, Wi-Fi and feedback codes.
- **Retailers and market traders** with payment, loyalty-card, offer and "scan to review" codes.
- **Event organisers and venues** with ticket, entry, programme and sponsor codes.
- **Freelancers and sole traders** who put a QR code on an invoice, business card or portfolio, and who get invoices and "documents" from other people.
- **Office managers and part-time IT helpers** who are asked to "sort out the security side" without a security team.

A word on tone. Nothing here is meant to make you feel careless. QR codes became everyday business tools very quickly, and almost nobody was given a manual. The people exploiting them are organised; the people running cafés and hotels are busy. The goal is to rebalance that a little.

How to Use This Book

You can read the book in an evening, or jump to what you need.

- **In a hurry?** Read the introduction, then Chapters 9 and 10 (inspect and secure your codes) and Appendix B (the weekly check). That alone removes most of your exposure.
- **Want to understand the threat?** Read Chapters 1 to 6 in order. They move from how a code works to the sticker, the fake page, the email and the invoice.
- **Run a venue, hotel or event?** Read Chapters 7 and 8, then Appendix A.
- **Take payments by QR?** Read Chapter 11 before anything else.
- **Something has already gone wrong?** Go straight to Chapter 13 and Appendix E.

Each chapter ends with a short action list. The appendices are designed to be printed, photocopied or pasted into a spreadsheet.

The Ten-Minute QR Exposure Check

Answer yes or no. Be honest; nobody is marking this.

1. Do you display at least one QR code that customers can reach without staff present (a table, a window, a poster, a counter)?
2. Do you know exactly where each of those codes leads, and who controls the page it leads to?
3. Does anyone check those codes physically, on a regular schedule?
4. Are any of your codes printed on plain paper or ordinary stickers, or stuck on with something that peels off cleanly?
5. Do you use a free online generator whose codes point through a third-party redirect address rather than your own domain?
6. Does a customer ever pay by scanning a code, with no one on your team checking the payment arrived?
7. Is your Wi-Fi password printed on a wall, a menu or a QR code that is also used for guests, staff and card machines?
8. Do you open PDF invoices or "shared documents" that ask you to scan a code with your phone?
9. Do your staff know what to do if a customer says "the code took me somewhere odd"?
0. Do you tell customers, anywhere, how to recognise your genuine code?

Scoring. Count your **yes** answers to questions 1, 4, 5, 6, 7 and 8. Then add one for each **no** to questions 2, 3, 9 and 10.

- **0 to 2:** good shape. Use the book to sharpen what you already do.
- **3 to 5:** typical. Chapters 9 to 12 hold several quick wins.
- **6 to 10:** worth an afternoon. Start with Chapter 9 and Appendix B this week.

CHAPTER 1

Why QR Codes Are Everywhere, and Why Criminals Like Them



QR codes were invented in 1994 by a Japanese engineer, Masahiro Hara, working for the car-parts maker Denso Wave, to track components on assembly lines.[8] For two decades they were a curiosity most people ignored. Then phones began to read them through the camera, restaurants reopened with contactless menus, and the habit stuck. Today a QR code is the default answer to a small business's question: *how do I get a customer from this physical thing to that digital thing, without typing?*



A table, a coffee and an empty stand: the most common QR code in the world sits here

What businesses use them for

- **Menus and ordering,** on tables, windows and counters.
- **Payments,** at the till, on a stand, on an invoice or a market stall.
- **Bookings and check-in,** at hotels, clinics, salons and events.
- **Wi-Fi access,** so guests do not have to type a long password.
- **Offers, reviews and social profiles,** on receipts, packaging and posters.
- **Tickets and entry passes,** on phones, wristbands and printed sheets.

Every one of these is a moment when a customer is about to trust something on the strength of where they found it.

Why criminals like them

Three properties make a QR code attractive to a fraudster:

1. **It hides the destination.** A link in an email can be read, hovered over and checked. A code is a picture. The address is inside it, and only the phone can see it.
2. **It crosses a boundary.** An emailed link is inspected by the company's email filters before it arrives. A code that is scanned from a screen, a printout or a poster is opened on a personal phone, outside the company network and often outside any protection at all.
3. **It borrows the trust of the place.** A code on a restaurant table feels like the restaurant. Nobody asks who put it there.

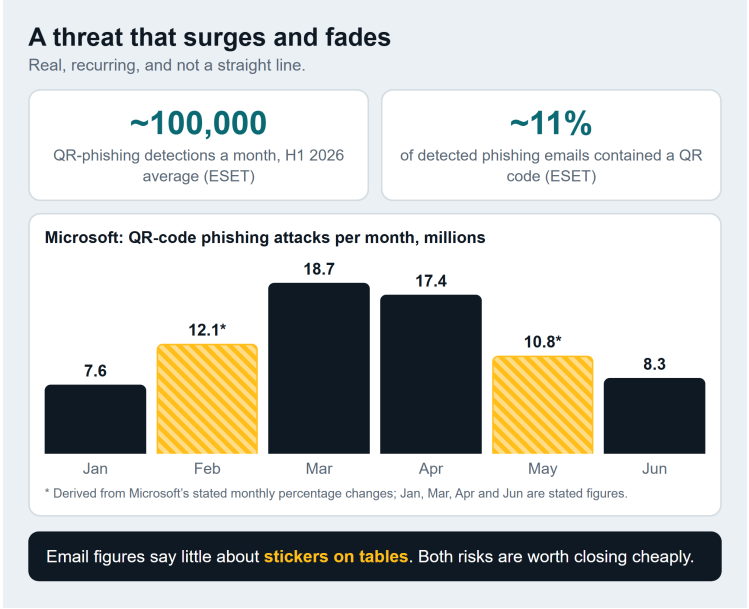
This is why the technique has its own name. **Quishing** is phishing carried by a QR code. It is not a new kind of crime. It is a familiar crime in a form that is harder to see.

What the numbers say, and what they do not

Two industry sources give a useful picture, and both come with a caution.

ESET's H1 2026 Threat Report describes record levels of QR-code phishing. Its telemetry averaged around **100,000 detections per month**, peaking in April, and QR codes appeared in around **11% of detected phishing emails**, with most detections in the United States, Spain and Mexico. The report period runs from December 2025 to May 2026.[1]

Microsoft's quarterly email-threat reports show a more volatile story. QR-code phishing attacks it observed rose from about **7.6 million in January to 18.7 million in March 2026**, a 146% increase over the quarter, the highest monthly volume in at least a year.[3] Then they fell in each of the next three months: 17.4 million in April, and a closing figure of **8.3 million in June**, a level last seen in mid-2025.[2]



Microsoft's monthly QR-code phishing volume, January to June 2026

What should a small business conclude?

- **QR phishing is real and recurring,** not a rumour.
- **It is not a steady climb.** Volumes swing sharply as criminals change tactics; Microsoft's Q1 surge was followed by a Q2 decline.
- **These figures count email.** They say little or nothing about stickers pasted on a table or a parking machine. The physical version is much harder to measure, which is not the same as rare.

So this book does not claim a wave that only goes up. It makes a narrower and safer claim: **QR codes are a standing weakness, and the cost of closing it is low.**

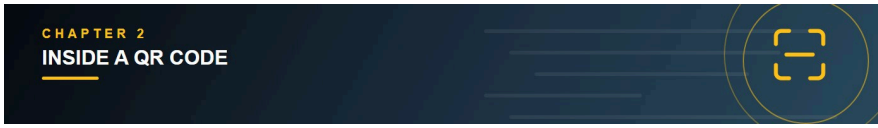
> **The rule.** A QR code proves nothing about who made it. Trust has to come from somewhere else: where it was placed, how it was checked, and what the page says when it opens.

Your actions

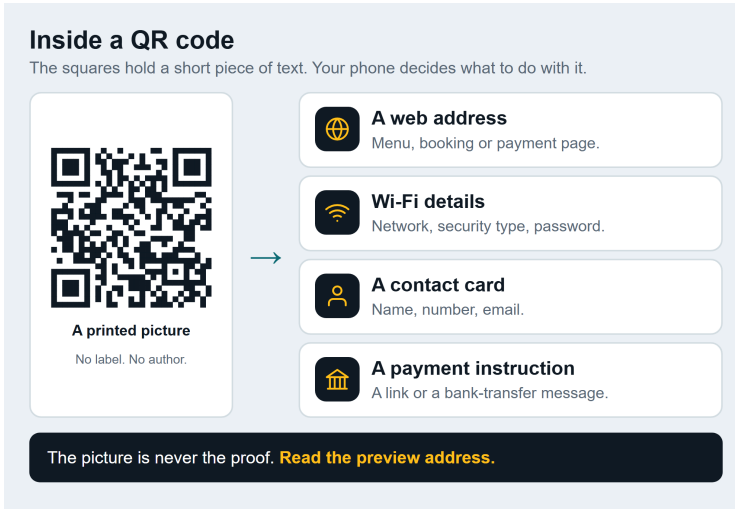
- ☐ List every place your business displays a QR code (Appendix A).
- ☐ List every place a QR code reaches your business: emails, invoices, posters, suppliers.

CHAPTER 2

Anatomy of a QR Code



A QR code, short for *quick response*, is a two-dimensional barcode: a grid of black and white squares that stores a short piece of data. Nothing mysterious is inside. What matters for your business is what *kind* of data, and who decides it.



A QR code is a pointer: what the squares can contain

What a code can contain

Most business codes hold one of four things:

- **A web address,** the common case: a menu, a payment page, a booking form.
- **Wi-Fi details:** the network name, the security type and the password, in a standard text format your phone understands.
- **A contact card,** so a phone can save a name and number.

- **A payment instruction,** which may be a link to a provider's payment page or a structured bank-transfer message. Some European banks use a standard format, the EPC QR code, to pre-fill a transfer.[9]

Your phone reads the text and then *offers to do something with it*: open a link, join a network, add a contact, start a payment. The danger is in what the person does next, not in the picture.

Static and dynamic codes

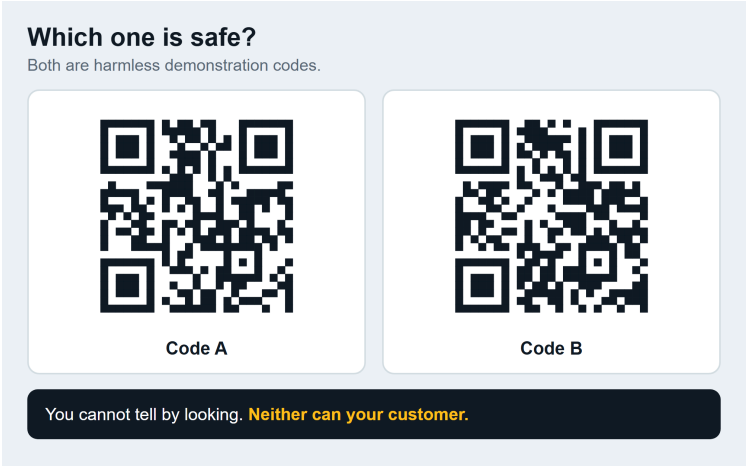
This is the most useful distinction in the book.

- A **static** code stores the destination directly. If you print it, the destination is fixed forever. Nobody can change where it points without replacing the printed code, but you cannot change it either, and you cannot see how many people scanned it.
- A **dynamic** code stores a short address owned by a code-generator service, which then forwards the visitor to the real destination. You can change the destination later without reprinting, and see scan counts. But there is now a **middleman**, and whoever controls the account controls where every printed code leads.

Dynamic codes are convenient and often the right choice. They also turn a printed sign into a remote-controlled one, so the account behind them needs the same protection as your bank login. Chapter 10 covers that.

What you cannot tell by looking

Nothing about the squares tells you who created the code, whether it is static or dynamic, or where it points. The two codes below are both harmless demonstration codes. One points to the author's companion site, the other to a neutral example page. You cannot tell which is which, and neither can a customer.



Two real codes, two different destinations. Look-alikes cannot be told apart by eye

Error correction: why damage still scans

Codes include built-in redundancy, so a code with a scuffed corner or a small logo in the middle still scans. This is good engineering, and it is also what makes some tampering possible: a code can be partially covered, altered or overlaid and still read cleanly.

What the phone shows

Modern phone cameras show a **preview of the destination** at the top of the screen before opening it. That preview is the only moment a customer sees the real address. It is also the habit this book wants you to build in your staff and your customers: **read the preview, not just the page.**

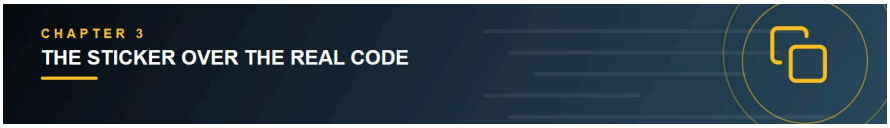
> **The rule.** The picture is never the proof. The address in the preview, and the page it opens, are the only evidence a customer gets.

Your actions

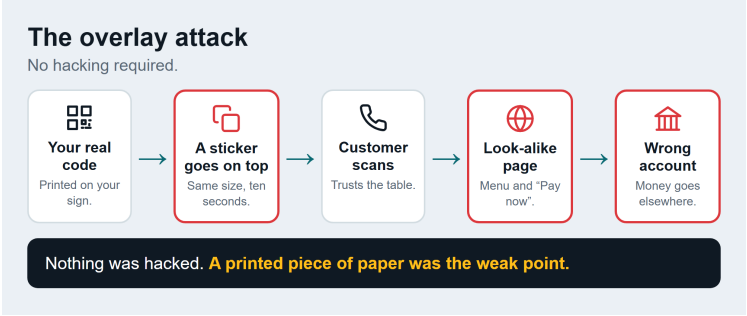
- ☐ Scan each of your own codes and write down the exact address your phone's preview shows.
- ☐ Note whether each code is static or dynamic.
- ☐ For each dynamic code, find out whose account controls it.

CHAPTER 3

The Sticker Over the Real Code



The simplest QR attack is physical and almost embarrassing. A criminal prints a code that leads somewhere they control, on a sticker the same size as yours, and sticks it on top.



How an overlay sticker redirects a customer's payment

How it works

1. The attacker photographs or measures your code and sign.
2. They print a fake code, often on a glossy or matt sticker chosen to blend with your material.
3. They walk in as a customer and place it on a table, a counter stand or a payment label.
4. Customers scan it, trusting the place. The page looks plausible, and may ask them to pay, log in or "confirm" something.
5. The attacker collects payments or credentials. You see nothing wrong until a customer complains, or until you notice money is missing.

No computer was breached. The weak point was a printed piece of paper on a public surface.

What the record shows

Official warnings are clearest for **parking machines**. In January 2022 the City of Austin in Texas reported that staff had checked more than 900 pay stations and found fraudulent QR codes on 29 of them; the city does not use QR codes for parking payment at all.[5] The same month the US FBI's Internet Crime Complaint Center published a public service announcement describing criminals who tamper with both digital and physical QR codes, including swapping a business's legitimate payment code for a malicious one.[4] Local reports of similar stickers on parking meters have continued since, in North America and elsewhere.

Documented cases on **restaurant tables** are thinner than the parking cases, and it is worth saying so plainly. The UK's National Cyber Security Centre has advised that codes in places like pubs and restaurants are probably safe to scan, while codes in open public spaces such as stations and car parks may be riskier.[6] That is a reasonable ranking. It does not make the table code risk-free: the technique is identical, the sticker costs pennies, and a busy venue with unattended tables is an easy place to apply one. The lack of a famous restaurant case is not evidence that it cannot happen. It is a reason to take the cheap precautions, which is what the rest of the book describes.

Why businesses are targets

- **Unattended surfaces.** A table or a window sign can be touched by anyone, at any time.
- **Many codes, little checking.** A venue with forty codes rarely examines all of them daily.
- **Payment attached.** A code that moves money is worth tampering with. A menu code is a way to phish.
- **A trusting routine.** Customers have scanned your code a hundred times. They do not look at the preview any more.

Signs of an overlay

Look and feel for:

- **A raised edge,** a corner that lifts, a faint rectangle outline, or glue residue.

- **A different finish:** glossier, thinner, or slightly different white from the sign beneath.
- **Misalignment:** the code is a few millimetres off, or does not match the logo and layout around it.
- **Two codes,** one half-covered by the other.
- **A code where there should not be one,** such as the back of a menu or the side of a stand.
- **Bubbles or creases,** from a quick press by hand.



Printed signs and cards: every one is a surface someone could cover

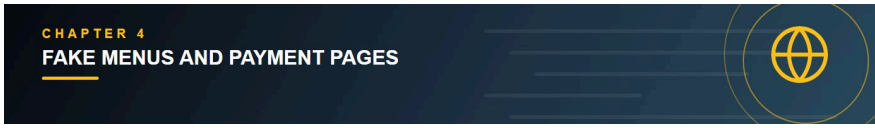
> **Fictional case: Nadia's café, continued.** Four of eleven tables had stickers. Nadia peeled them off, found that the page they led to captured card details, and had no way of knowing how many customers had paid. Her mistake was not the QR menu. It was that nobody had ever checked the tables.

Your actions

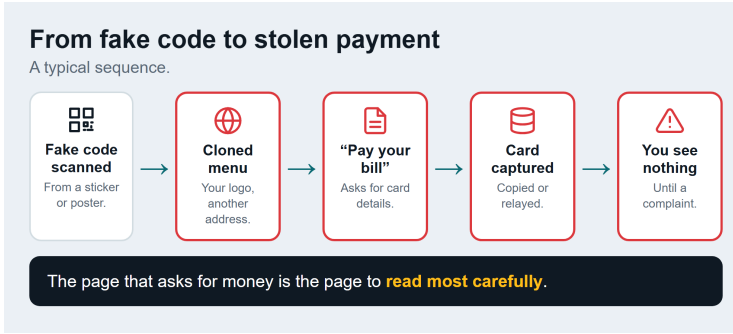
- ☐ Walk your premises today and touch every code. Run a fingernail along the edges.
- ☐ Photograph each genuine code once so you have a reference.
- ☐ Decide who checks the codes, and how often (Appendix B).

CHAPTER 4

Fake Menus and Fake Payment Pages



When a customer scans a diverted code, what happens next decides the cost. The most common destination is a page built to look like yours.



The path from a scanned fake code to a stolen card payment

The cloned menu

A criminal copies your public menu, logo and colours, and hosts the copy on a page with a similar name. To a hurried customer it is indistinguishable. The look-alike address might be:

- **A different ending:** your name followed by a word like "menu", "order" or "pay".
- **A typo or swapped letter,** easy to miss on a small phone screen.
- **A free-hosting address,** with your name as a prefix and a generic provider after it.
- **A long address** where the real domain is buried at the end.

An illustrative defanged example, for a fictional café: `harbourcafe-menu[.]example` instead of the genuine `harbourcafe[.]example`. Customers on a phone often see only the start of the address.

What the fake page asks for

- **A card payment,** presented as "pay your bill" or "add a tip". The page captures the card number and may relay it in real time.
- **A login,** presented as "sign in to view the menu" or "log in to earn points". The page captures an email and password.
- **An app download,** presented as "get our app for a discount". The file may be malicious.
- **A "deposit",** presented as "confirm your table" or "secure your reservation".
- **A support message,** presented as a chat window that walks the customer through paying "to fix a problem".

Why the fake works

Customers do not distrust a page that loads. They distrust a request that is unusual. So the best fakes ask for exactly what your real page asks for: something a customer has done before. Three habits make the difference:

1. Customers rarely read the address.
2. Menus that were free to open now ask to log in, which has become normal.
3. Pay-at-table flows are new enough that people accept different layouts without suspicion.

Your side of the page

The same trust works in reverse. If **your own** real menu page asks for a login, loads advertising, or sends visitors through a redirect chain, you teach customers that anything goes. A clean, simple page with your name and domain is itself a defence, because customers learn what normal looks like. Chapter 12 returns to this.



A market stall at night: every printed menu and sign is a possible swap

Pay-at-table: a special case

When a code takes payment, a diverted code means a **real payment goes to the wrong place**. The customer believes they have paid. You do not receive the money. The bill remains open, and the dispute lands on your counter. Chapter 11 shows how to design payment so you find out within minutes.

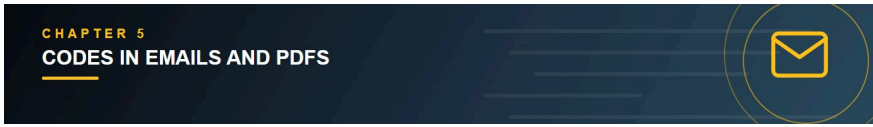
> **The rule.** A page that asks for a card, a login or a download after a scan deserves the same scrutiny as an email that asks for them.

Your actions

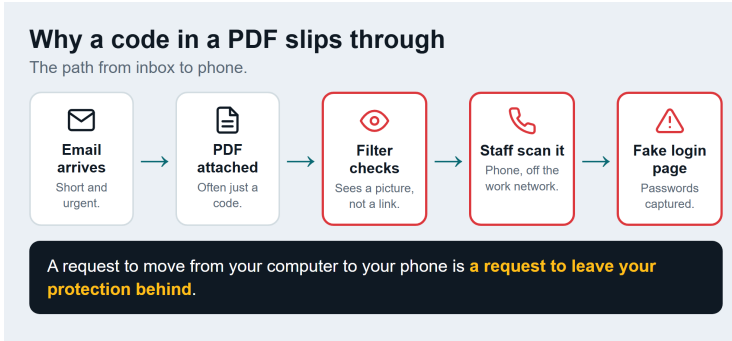
- ☐ Open your menu and payment pages on a phone. Does the address read clearly as yours?
- ☐ Remove anything unnecessary: forced logins, pop-ups, "download our app" prompts.
- ☐ Register the obvious look-alike domains or at least know them.

CHAPTER 5

QR Codes in Emails and PDFs



The physical sticker needs someone to walk into your premises. The emailed version does not. It arrives in your inbox, and it is where most of the measured volume sits.



Why a code in an attachment slips past link checks and lands on a personal phone

Why attackers swap a link for a code

An email security filter reads the links in a message and checks them against lists of known bad addresses. A QR code is an **image**. Unless the filter reads images, it sees a picture, not a link. The recipient is then asked to scan it with a phone, which is typically **outside the company's protections** and has no link-rewriting or sandboxing.

The usual cover stories are familiar:

- *"Scan to view the shared document."*
- *"Your account needs to be re-verified. Scan the code."*
- *"Scan to approve this payment / confirm this delivery."*
- *"Multi-factor authentication update required."*

The PDF is the favourite container

Microsoft's reporting is revealing about *where* the code sits. In Q1 2026 PDF attachments carried around **65% to 70%** of the QR-code attacks it tracked, with Word documents most of the rest. In Q2 the PDF share peaked at **79% in April** and then fell to about **58% by June**, while Word documents rose to roughly 40%. Codes embedded directly in the body of an email, which had briefly surged in March, **all but disappeared** in the second quarter.[2][3]

The pattern is worth noticing even if the exact shares move: attackers keep adapting to wherever the filters are weakest. Defences that watch one place push the activity into another.

How to spot one

A QR code in an email or attachment is a **warning sign by itself** when:

- you were not expecting any document from the sender;
- the message creates urgency ("expires today", "final notice");
- the code replaces a normal link or button, and there is no reason a phone is needed;
- the message asks you to move from your computer to your phone;
- the sender, address or branding is *almost* right, but not quite;
- the attachment is a PDF with almost nothing in it except the code and a short instruction.

> **The rule.** A message that asks you to take a task off your work computer and onto your phone is asking you to leave the protection that would have caught it.

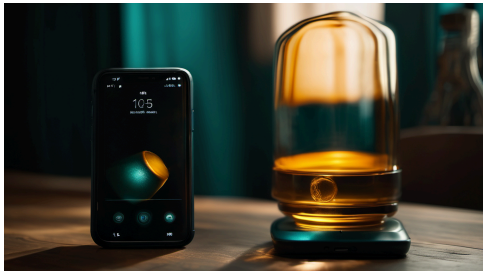
What to do instead

- **Do not scan it.** Contact the sender using a phone number or address you already have, not one in the message.
- **Report it** to whoever handles IT or email for your business, and delete it.
- **If you already scanned,** do not enter anything. Close the page, then follow Chapter 13.

- **Enable what you have.** If your email platform offers QR-code or image scanning, turn it on. If you use multi-factor authentication, prefer methods that cannot be intercepted by a fake page.

A word on staff

Most small businesses have no security team. The person who opens the inbox *is* the control. Five minutes of briefing (Appendix C) does more than any tool: *no unexpected QR code from an email, ever; ask first.*



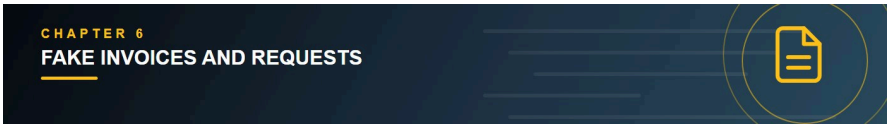
A phone beside a keyboard: where a QR scan quietly leaves the work network

Your actions

- ☐ Tell everyone who reads the inbox: unexpected QR codes in email are never scanned.
- ☐ Agree who staff ask when they are unsure.
- ☐ Check whether your email platform can scan images or QR codes, and turn it on.

CHAPTER 6

Fake Invoices and Supplier Requests



For a freelancer or small supplier, the most expensive QR code may not be on a wall. It is on an invoice.

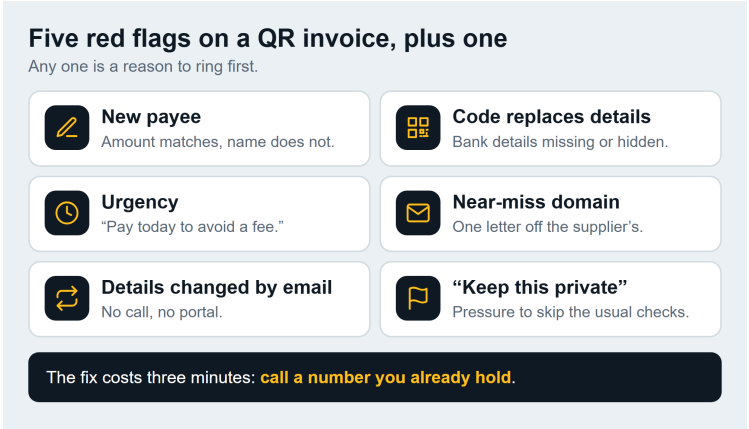
The pay-here invoice

Fraudsters send convincing invoices that look like they come from a real supplier or a service you use. Instead of bank details, the invoice has a QR code and the line *"Scan to pay securely."* The code opens a payment page that captures card details, or a bank-transfer instruction that sends the money to the criminal's account.

Sometimes the invoice is wholly fake. More dangerous is the invoice that is **a real supplier's real document, altered**: the same layout, amounts and reference, with one change, the payment code or the account number.

The changed-details request

A close relative is the "we have changed bank" message. A supplier appears to write that its account has moved, and attaches an updated invoice with a new QR code. Because the relationship is real and the amounts match, accounts staff go along.



Five red flags on a QR invoice

Red flags worth a pause

- A **change of payment method or account** announced by email only.
- A QR code **in place of** the bank details you normally see.
- A request to pay **urgently**, or to **keep the change confidential**.
- A **domain** that is close to the supplier's but not identical.
- An amount or reference that matches, but a **new** payee name.
- A document that was **not sent through the usual route** (portal, named contact, usual address).

The call-back rule

The simplest control is also the best. **Never change payment details because an email, PDF or code told you to.** Use a phone number you already hold, from a contract or a previous invoice, to confirm any change. Write down who confirmed and when. It adds three minutes and prevents a loss that can be large and hard to recover.

If you send invoices with a QR code

A code on your own invoices is a convenience for customers, and a target. Two precautions:

1. **Print the bank details in text too,** so a customer can compare the code's payee with the text.

2. **Say so on the invoice:** "We will never change our bank details by email. If in doubt, ring us."

This sentence costs nothing and teaches your customers the call-back rule too.

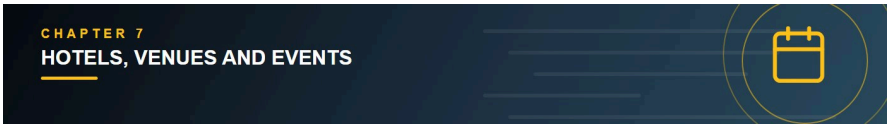
> **Fictional case: Kofi, freelance photographer.** Kofi's biggest client received an invoice that looked exactly like his. The only change was the QR code at the bottom. The client's accountant rang Kofi on the number in the original contract. The invoice was a fake created from a leaked PDF. The call took four minutes.

Your actions

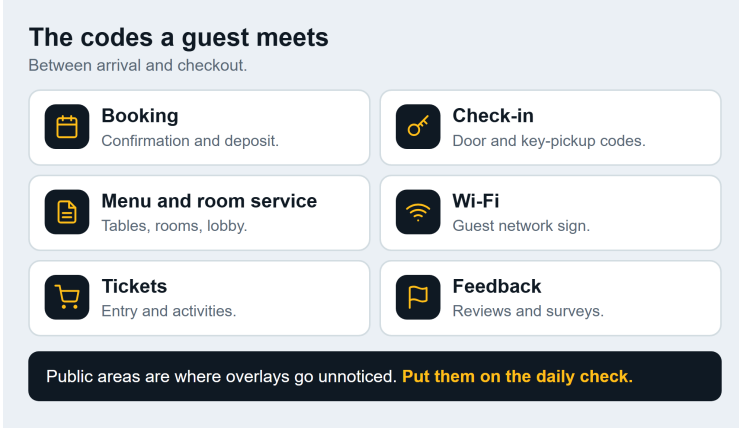
- ☐ Adopt the call-back rule for every change of payment details.
- ☐ Add a "we never change bank details by email" line to your invoices.
- ☐ Print account details in text next to any payment code.

CHAPTER 7

Hotels, Venues and Events



A hotel, guesthouse or event runs on QR codes more than almost any other business: check-in, booking, Wi-Fi, menus, feedback, activities, tickets.



The codes a guest meets between arrival and checkout



A reception desk at night: dozens of small chances for a code to be copied or replaced

The booking trail

Guests are used to receiving messages about a booking. Fraudsters imitate that routine. A common pattern is a message that appears to come from the hotel or a booking platform, with a QR code to "confirm your deposit" or "verify your card". The code leads to a copy of the real page.

For a small property, there are two directions of risk:

- **Fake messages to your guests,** using your name. You rarely see them, but guests blame you.
- **Fake messages to you,** pretending to be a booking platform, with a QR code or link to "verify your account". If a criminal gets into your platform login, they can message your guests from your real account.

Check-in and room codes

Self-check-in codes, door information and key-pickup codes are sensitive. Treat them like keys:

- Send them only through the booking platform or a channel you control.
- Make them **single-use or time-limited** where the system allows.
- Never print a code for several rooms on a shared sheet.

Posters and in-room signs

A QR code on a lobby poster for "tours and activities" is an invitation to anyone to place their own. Unattended public areas of a hotel are exactly where overlays go unnoticed. Put a staff check on the daily housekeeping list.

Events: tickets and entry

Ticket QR codes are a different problem. The danger is not a fake page but a **copied ticket**. If a ticket's code is posted online, or a screenshot is shared, someone else may scan it first and your genuine guest is refused entry.

- Use **one-time or rotating codes** where the ticketing system supports them.
- Tell guests **not to post tickets** online, even with the code "blurred": a partial image can be enough.
- Have staff **scan from the app**, not read the code by eye, so that a duplicate is flagged.
- Prepare a **manual fallback** for guests whose code is refused.

Sponsors, partners and stalls

At a market or event, many other people display codes on your site: stallholders, sponsors, food vendors. Their codes are not yours, but customers will assume they are your responsibility. Set a rule that all printed codes at your event are **checked before opening**, and that you may ask a vendor to remove one.

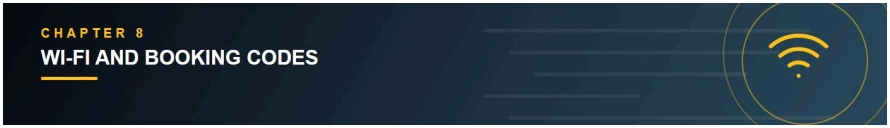
> **Fictional case: Lumen Night Market.** Ines, the organiser, found two "pay here" stickers on a vendor's counter an hour after opening. The vendor was innocent. The stickers were placed on top of the vendor's own code during setup. A morning check would have found them.

Your actions

- ☐ Add a QR check to the opening and closing routine of every public area.
- ☐ Send booking codes only through channels you control.
- ☐ For events, agree who verifies vendor codes before gates open.

CHAPTER 8

Protecting Your Wi-Fi and Booking Codes



Two of the most common business QR codes are the **Wi-Fi code** and the **booking or reservation code**. Both leave the printed sign and go straight into a customer's phone.



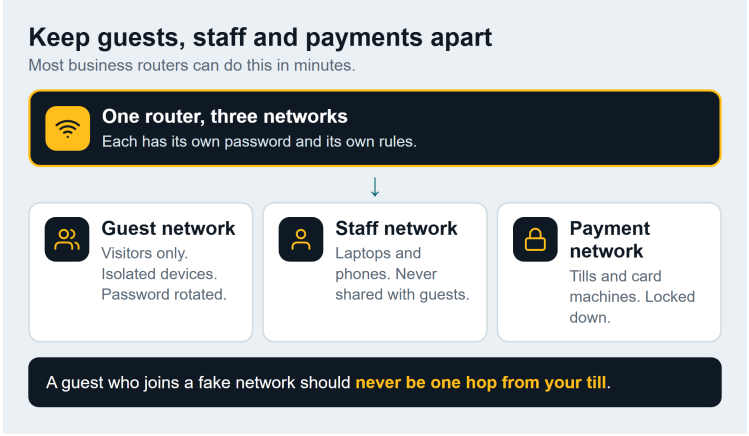
A softly lit router: the cheapest piece of equipment in the building, and the one that connects everything

How a Wi-Fi code works

A Wi-Fi QR code contains the network name, the security type and the password in a standard text format. The phone offers to join the network when scanned. Genuine and convenient.

The risks:

- **The password is on the wall.** Anyone can photograph it and keep using the network indefinitely.
- **A fake code points to a fake network.** An attacker sets up a hotspot with a look-alike name and replaces your code. Customers join it and their traffic can be read or altered.
- **Everyone is on one network.** Customer phones, staff laptops, card machines and cameras share a network, so one weak device exposes the rest.



One building, three networks: guests, staff and payments kept apart

What to do

1. **Make a guest network** separate from staff and payment systems. Most business routers support this in a few minutes. Name it clearly and give it a different password.
2. **Isolate guests from each other** and from your internal devices, where the router has a "client isolation" option.
3. **Rotate the guest password** regularly, and always after a staff change or a suspected problem. Reprint the code.
4. **Never use the staff or payment network password for guests.**
5. **Keep card machines and tills on their own network,** or on mobile data, so a compromised guest cannot reach them.
6. **Update the router** and change its default administrator password. A router is a computer.
7. **Check the sign.** A fake code that looks like your Wi-Fi sign should be detected in the daily check.

Booking and reservation codes

The same logic applies to codes that lead to a booking form, a table-reservation page or a calendar. Anyone who changes them can send your customers to a copy that takes a deposit.

- Use **your own domain,** not a third-party redirect.
- **Test the code** monthly by scanning it as a customer would.

- Print the **short address in text beside the code** so customers can type it if they prefer.
- Never take a deposit on a page you cannot control and cannot see in your provider's records.

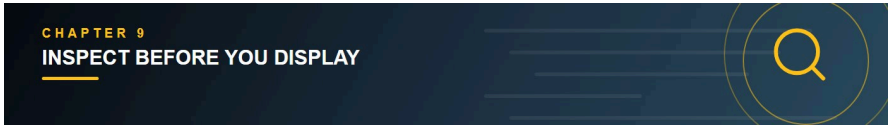
> **The rule.** Give guests a way to join and book that you could change in five minutes, and cannot be turned against your own systems.

Your actions

- ☐ Set up a guest Wi-Fi network separate from staff and payment devices.
- ☐ Change the guest password and reprint the code on a set schedule.
- ☐ Print the web address in text beside every booking code.

CHAPTER 9

How to Inspect a QR Code Before You Display It



You would not hang a sign over your door without reading it. A QR code deserves the same care, because the words are hidden. This chapter gives you a repeatable inspection, to use on every code you create, receive or display.

The six-point inspection

Use it on every code you create, receive or display.

1. **Source**
   Who made it, with what tool?
2. **Destination**
   Read the preview address. Is the domain exactly yours?
3. **Redirects**
   Does the address change on the way?
4. **Page behaviour**
   Only what it promises: no logins, pop-ups or downloads.
5. **Physical code**
   Print quality, margin, material, edges and residue.
6. **Record**
   Photograph it, log it, give it a reference.

If you cannot say who made it, where it points and when it was last checked, **it is not ready to display**.

The six-point QR inspection

Point 1: Source

Who created this code, and with what? If you made it yourself with a generator, note which one. If a printer, designer or supplier made it, ask them. A code that arrived from someone else, such as a sponsor's poster, is not yours until you have checked it.

Point 2: Destination

Scan it with your phone's **built-in camera**, not a random scanner app. Read the **preview address** that appears and write it down. Then check:

- Is it **your domain,** spelled exactly right?
- Does the **end** of the address (the part just before the first single slash) match your domain? Criminals bury a real-looking name at the start.
- Is it a **short link or redirect** from a third party? If so, who controls that account?
- Does it contain **long random strings** or tracking parameters you did not add?

A tip for a safer test: use a spare phone, or a phone with no payment or work accounts signed in, so the page cannot do harm if it turns out to be bad.

Point 3: Redirects

Open the page and watch the address bar. Does it **change** between the scan and the final page? Some redirects are normal; unexplained ones are not. Fix any you cannot explain.

Point 4: Page behaviour

The page should do **only what the code promises.** A menu code should show a menu. Be alert for:

- a request to **log in** or create an account to see something that should be public;
- a **pop-up** or banner asking for a card or phone number;
- a prompt to **download** an app or file;
- a payment page that does not show **your name** as the payee.

A padlock symbol in the address bar only means the connection is encrypted. Criminals can have padlocks too. It is not proof of honesty.

Point 5: The physical code

Examine the object, not just the squares:

- **Print quality:** crisp edges, solid black, white that matches the sign.
- **Size and spacing:** a clear blank margin around the code, correct proportions.
- **Contrast:** dark squares on a light background. Coloured or reversed codes often fail on older phones.
- **Material:** is it printed on the sign, or stuck on top? Print on the sign wherever possible.
- **Wear:** do corners lift? Is there glue or residue?

Point 6: Record

Photograph the code, write down its destination and location, and give it a **reference number**. A code with no record cannot be audited. Appendix A is the template.

How often?

- **When created or replaced:** all six points.
- **Weekly:** points 2 and 5 on every public code (Appendix B).
- **Daily, in public areas:** a quick look and touch for stickers, as part of opening routines.

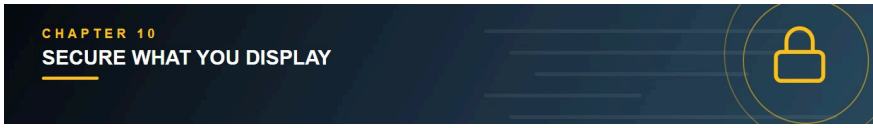
> **The rule.** If you cannot say who made a code, where it points and when it was last checked, it is not ready to display.

Your actions

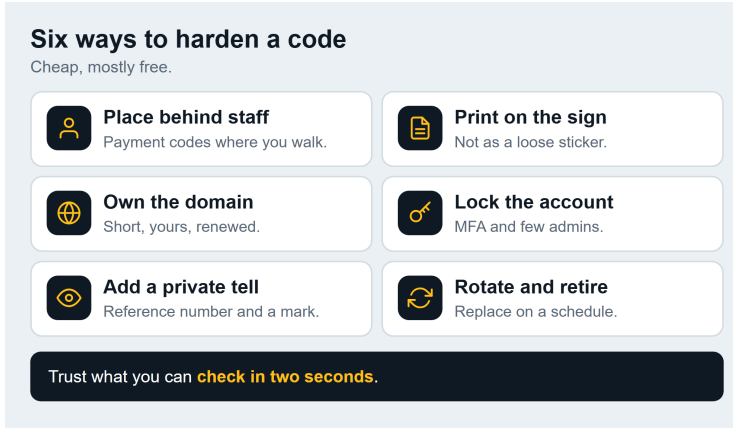
- ☐ Inspect every code you display, using the six points.
- ☐ Give each code a reference number and photograph it.
- ☐ Put the weekly check in the calendar (Appendix B).

CHAPTER 10

Securing the Codes You Display



Inspection finds problems. This chapter makes them less likely to happen. The ideas fall into four groups: **place, print, own and mark.**



Six ways to make a displayed code harder to tamper with

Place: where the code lives

- **Keep payment codes behind staff.** A code that moves money belongs at the counter or on a card machine that staff see all day, not on an unattended table.
- **Put codes where you walk.** The more often a team member passes a code, the sooner a sticker is noticed.
- **Mount, do not stick.** A code in a frame, a table-stand or a sealed holder is harder to cover than a flat paper sign.
- **Reduce the number.** Every code is a thing to check. Ask whether each one needs to exist.

Print: what the code is made of

- **Print the code on the sign** itself, not as a separate sticker.
- Choose **materials that show tampering:** tamper-evident labels that leave a mark if removed, engraved or etched stands, laminated cards that tear if a sticker is peeled.
- **Make the sign hard to imitate:** a distinctive border, a logo, a small design element a copy would miss.
- Print the **web address in text** beside the code, so the destination is visible to anyone.

Own: who controls the destination

- **Use your own domain** for any code that matters, not a long free-hosting address. A short, memorable domain also gives customers something to check.
- **Renew it, and watch the expiry date.** If a domain lapses, someone else can register it, and every printed code you have becomes theirs. This is a surprisingly real risk with old signs and flyers.
- **Protect the generator account** for any dynamic code: a strong unique password, **multi-factor authentication,** as few administrators as possible, and a log of who has access. Remove former staff at once.
- **Avoid free generators** that route scans through an advertising or tracking page, or that expire the code after a trial. A code that stops working, or starts showing adverts, is worse than none.
- **Ask your provider** what happens to old codes if you cancel, and whether they can be redirected without your approval.

Mark: private tells

A **private tell** is a small feature only your staff know about, which a copy would lack. It can be a tiny notch in the corner of the sign, a particular colour of border, or a reference number (such as T7) printed in a fixed place. It costs nothing, and it lets any member of staff confirm in two seconds that a code is the one you printed.



Every printed sign is a record you can check against a reference

Rotate and retire

Treat codes as having a **lifespan.** Replace table signs on a schedule, so a copy that was made last season stops working. Remove codes for finished promotions. An old poster with a live code is an open invitation.

Staff

A rule nobody knows will not be followed. Give staff three instructions (Appendix C):

1. **Look and touch** every code you pass.
2. **Never remove a code** you did not put there; photograph and report it.
3. **Tell the manager** if a customer mentions a strange page.

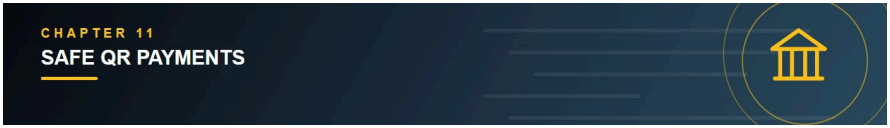
> **The rule.** Put as much trust as possible in things you can check quickly: your domain, your material, your reference number.

Your actions

- ☐ Move payment codes to staffed locations.
- ☐ Add a private tell and a reference number to every printed code.
- ☐ Secure the generator account with MFA and a short list of administrators.
- ☐ Check the renewal date of the domain behind every code.

CHAPTER 11

Safe Payments: Setting Up QR Payments So Problems Show Up Fast



Payment is where a diverted code costs the most, and where good design pays back quickly. The aim is not to make diversion impossible. It is to make sure you **notice within minutes, not weeks.**



A payment terminal: the place where the amount, the payee and the receipt should all be visible

Static and dynamic payment codes

A **static** payment code is the same for every customer. The customer types the amount. It is easy to display and easy to replace with a criminal's code. A **dynamic** payment code is generated per bill or per order, with the amount and reference already filled in, and is shown on a screen or receipt at the moment of payment. A dynamic code is harder to substitute, because a sticker cannot know today's bill.

Where your provider offers it, prefer **dynamic codes shown on a screen or printed for each bill** over a permanent sign.

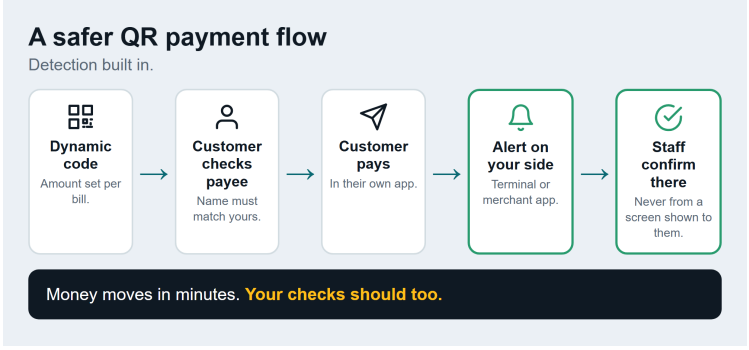
Design for detection

Put in place the three things that make a diverted payment visible:

1. **A payee name the customer can check.** Payment apps show the receiving name before confirming. Make sure your trading name is correct there and train staff to say, "check that it shows [your name]".
2. **A confirmation that only you can see.** Staff should confirm payment in **your own provider's app, terminal or dashboard,** never from a screen the customer holds up.
3. **A daily reconciliation.** Compare the day's sales with the day's receipts. A gap is the first sign of diversion.

Never trust a screenshot

A fake payment confirmation is easy to make. A customer, or a criminal posing as one, can hold up a screen that says "Payment complete". Staff should always check the **merchant side,** where the payment arrives, and only then release goods or close the bill. Make this a standing rule, politely stated: "I just need to see it on our system."



A safer QR payment flow: the confirmation comes from your side, not the customer's screen

Alerts and limits

- Turn on **instant notifications** for incoming payments, to a device someone is watching.
- Ask your provider about **unusual-payment alerts** and **account-change alerts,** so you are told if bank details on your account are changed.
- Restrict who can **change the settlement account** and require a second person to approve it.
- Keep **receipt and refund** permissions to a few staff.

If a customer says they paid but you do not see it

Do not accuse them, and do not assume. It may be a slow payment, a mistake, or a diverted code. Check, take a note of the time, the amount and what they scanned, and photograph the code in question. If you suspect a fake, go straight to Chapter 13.

Questions for your payment provider

Ask them, in writing, and keep the answers:

- How are losses handled if a customer pays through a code that was not ours?
- Can we receive instant alerts and daily settlement reports?
- Can the code be locked to our merchant ID, so a copy cannot be repointed?
- What is the process to report fraud, and how quickly can a payee account be frozen?

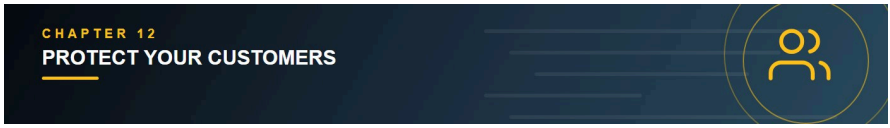
> **The rule.** Money moves in minutes. Your checks should too.

Your actions

- ☐ Move to dynamic, per-bill payment codes if your provider supports them.
- ☐ Add a "confirm on our system" step to every payment, and brief staff.
- ☐ Turn on instant payment alerts and a daily reconciliation.

CHAPTER 12

Protecting Your Customers



Your customers are the people criminals actually want. You can protect them by teaching them, quietly and consistently, what your real code looks like.

A sign that teaches

Fictional table sign, ready to adapt (Appendix D).

HARBOUR CAFÉ · OUR OFFICIAL MENU

T7

- Check the address starts with **harbourcafe.example**
- We never ask for card details after a scan, except at the till.
- Looks different? **Tell us.**

One short sentence next to a code does more than a long policy.

A short, plain notice that teaches customers what you will and will not ask

Say it where the code is

A small line next to every code works better than a long policy:

- *"Our only official code. Check the address starts with [yourdomain]."*
- *"We never ask for card details after a scan except at the till or terminal."*
- *"If it looks different, tell us."*

Customers do not need to understand how fraud works. They need one simple habit: **read the address.**

Keep your pages boring

Your real pages are part of the lesson. Keep them simple and consistent:

- the same domain every time;
- no forced logins to read a menu;
- no unexpected pop-ups, downloads or redirects;
- your business name in the payment page and on the receipt;
- a clear contact line.

When the genuine thing is predictable, a fake that is different stands out.

Say what you will never do

State plainly in your messages, on your website and on signs:

- We will **never** ask for a card number by message or email.
- We will **never** ask you to scan a code to "fix", "confirm" or "release" a payment.
- We will **never** change our bank details by email.
- If you are unsure, **ring us** on the number on our website.

Handle reports well

When a customer says, "the code took me somewhere odd," **thank them and act.** They have just found a problem for you. Take their name, what they scanned, where and when, and what the page asked for. Then check the code. Customers who are made to feel foolish stop reporting.

Your own privacy duties

If your real QR pages collect any personal data (names, emails, phone numbers, bookings, payments), the usual data-protection duties apply: a clear notice, only what you need, and secure handling. A page that over-collects makes it harder for customers to spot a fake that over-collects too. If you operate in the EU or UK, the GDPR applies to the personal data your pages collect, and GDPRGard.eu has plain-English tools for small businesses.

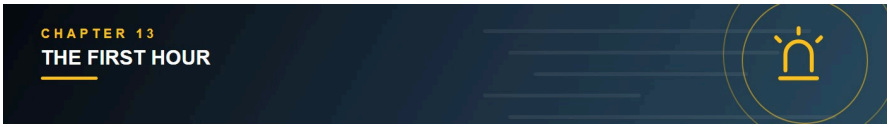
> **Fictional case: Hotel Marina Verde.** After a scam in which a copied booking page took deposits in its name, the owners added one line to every booking confirmation: "We never ask for a deposit by QR code or message. Our only payment page is [address]." Guest reports of suspicious messages rose in the following month, because guests now knew what to report.

Your actions

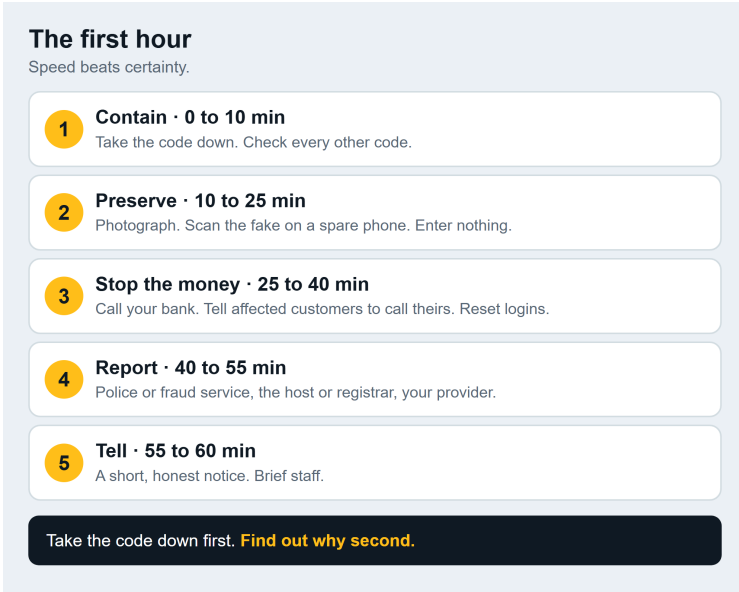
- ☐ Add a one-line "official code" notice next to every public code.
- ☐ Add "we will never..." wording to confirmations and invoices.
- ☐ Agree how reports from customers are logged and followed up.

CHAPTER 13

When It Goes Wrong: The First Hour



Someone tells you a code looked odd. You find a sticker. A customer says money has gone. The first hour decides how much damage follows.



The first hour: contain, preserve, stop the money, report, tell

Minute 0 to 10: contain

- **Take the code down.** Remove or cover every code you suspect, and block off the area if needed. A temporary handwritten sign ("Menu at the counter, please ask") is fine.
- **Check the neighbours.** If one code was tampered with, look at all of them, today.
- **Do not throw anything away.** A sticker you peeled off is evidence.

Minute 10 to 25: preserve

- **Photograph** the tampered code in place, from several angles, with the time and location.
- **Scan the fake on a spare phone** with nothing signed in. Write down the address, take screenshots of every page, and **do not enter any data.**
- **Write down** who reported it, what they scanned and what they paid.

Minute 25 to 40: stop the money

- **Call your bank or payment provider.** Tell them a payment code was tampered with, give the times and amounts, and ask them to flag or block the receiving account where possible.
- **Tell affected customers** to contact **their** bank straight away. The sooner a bank is told about a payment, the more it can sometimes do.
- **Reset credentials** if there is any chance a login was exposed: the code-generator account, booking platform, email and payment dashboard.

Minute 40 to 55: report

- **Report to the police or national fraud service.** Examples include Action Fraud in the UK, the FBI's Internet Crime Complaint Center (IC3) in the US, or your national cyber-security centre or police reporting portal elsewhere.[4]
- **Report the fake page** to the hosting provider or domain registrar (they usually have an abuse contact) and to browser safe-browsing services, so the page can be blocked.
- **Tell your payment provider** what you found, in writing.

Minute 55 to 60: tell

- **Post a short, honest notice** at the venue and online: what happened, what to do, who to contact. Avoid blame and jargon.
- **Brief staff** in two sentences so everyone says the same thing.

Is it a data breach?

A fake sticker on your table redirecting customers to a criminal's page is not, on its own, a breach of *your* systems. But the situation changes if **your own account or system was compromised** (for example, someone changed the destination of your dynamic code, or logged in to your booking platform and messaged guests). In that case you may have a **personal data breach** under the GDPR. If so, the controller must assess the risk to individuals and, unless the breach is unlikely to result in a risk, notify the supervisory authority **without undue delay and, where feasible, within 72 hours** of becoming aware, and tell affected people if the risk is high.[7] When in doubt, record what you decided and why, and ask your data-protection authority or an adviser.

Afterwards

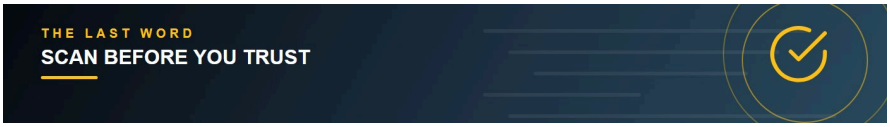
Within a week, run a short review: how did it happen, how was it found, what check would have found it sooner? Update Appendix A and B. Replace the code. Add the lesson to the staff briefing. Then tell customers what you changed.

> **The rule.** Speed beats certainty. Take the code down first and find out why second.

Your actions

- ☐ Print Appendix E and keep a copy where the team can find it.
- ☐ Write the phone numbers you would need (bank, provider, police, registrar) in one place.
- ☐ Decide who decides when a code comes down.

Conclusion: Scan Before You Trust



QR codes will keep being printed, scanned and copied. Criminals will keep switching between stickers, emails, PDFs and fake pages, because they follow the weakest point. The numbers will rise and fall, as the first chapter showed. The habits that protect you do not change.

Three ideas are worth keeping.

Inspect. Know where every code you display leads, and look at it again regularly. A code you cannot account for is a code you cannot trust.

Own. Put your codes on your domain, on your material, under accounts you protect. Make payments confirm on your side, not on a customer's screen.

Tell. Tell your staff what to look for and your customers what the real thing looks like. A short sentence beside a code is cheaper than any tool.

Scan before you trust. And when you ask others to scan, give them a reason to.

APPENDIX A

QR Code Inventory

Build this as a spreadsheet. One row per code you display, and one per category of code that reaches you. Photograph each code and store the photo with its reference number.

Ref	Location	Purpose	Destination address (from preview)	Static or dynamic	Account owner	Domain renewal date	Last checked	Checked by
T1	Table 1	Menu						
T2	Table 2	Menu						
C1	Counter	Payment						
W1	Window	Offers						
R1	Reception	Wi-Fi						
R2	Reception	Booking						
E1	Entrance	Tickets						
I1	Invoices	Payment						

Code categories: Menu, Payment, Booking, Wi-Fi, Ticket, Offer, Review, Social, Other.

Rule: a code with an empty destination, owner or date does not go on display.

APPENDIX B

The Weekly Check Log

Print one per week. A code is only "checked" if it was touched and scanned, not just looked at.

Week starting: _____ **Checked by:** _____

Ref	Present and unchanged?	Edges flat, no residue?	Preview address correct?	Page behaves normally?	Private tell present?	Notes

Daily quick check (opening and closing)

- ☐ Walked past every public code
- ☐ Touched the edge of each one
- ☐ Nothing new, nothing moved
- ☐ Wi-Fi sign matches the network name
- ☐ Payment code staffed and in place

If anything is wrong: take the code down, photograph it, and follow Appendix E.

APPENDIX C

One-Page Staff Briefing

Copy this page, read it aloud once, and pin it where staff will see it.

What we do

1. **Look and touch** every code you walk past. Does it look the same as yesterday?
2. **Check the private tell** (the reference number and mark) on any payment code.
3. **Confirm payments on our system,** never from a customer's screen.
4. **Ask before you scan.** If an email, invoice or message contains a QR code you did not expect, do not scan it. Ask _____.
5. **Take it seriously** if a customer says a code took them somewhere odd. Thank them and tell _____.

What we never do

- Remove or move a code we did not put there (photograph and report it).
- Change payment details because of an email, PDF or QR code.
- Give the guest Wi-Fi password for the staff or payment networks.
- Scan a code on a personal phone that is signed in to work accounts, to "just check".

If you find something odd

1. Cover or remove the code. 2. Photograph it. 3. Tell _____ straight away.

Phone numbers

Manager: _____ Bank or payment provider: _____ IT helper: _____

APPENDIX D

Wording for Signs and Messages

Adapt and reuse. Keep the sentences short.

Beside a menu code

Our official menu. Check the address starts with _____.

Beside a payment code

Pay here. The payee shown on your phone should read _____. If it does not, stop and ask us.

On a Wi-Fi sign

Guest Wi-Fi: _____. Ask staff if the network name looks different.

In booking confirmations

We will never ask you to pay a deposit, or confirm card details, by QR code or message. Our only booking page is _____. If you are unsure, ring _____.

On invoices

We will never change our bank details by email. If you receive a message saying we have, ring us before paying.

After an incident

We found that a QR code on _____ had been tampered with on _____. If you scanned it, please do not enter any more information, and contact your bank if you made a payment. We have replaced all codes and reported this to _____. Contact _____ with any questions.

APPENDIX E

Incident Response Checklist

Print and keep where the team can find it. Tick and time each step.

Incident reference: _____ **Date and time found:** _____
Found by: _____

Contain (0 to 10 minutes)

- ☐ Suspect code(s) removed or covered
- ☐ All other public codes checked
- ☐ Removed items kept safe as evidence

Preserve (10 to 25 minutes)

- ☐ Photos taken, in place and close up
- ☐ Fake page scanned on a spare, signed-out phone; address and screenshots saved
- ☐ No data entered into the fake page
- ☐ Witness details and what they paid noted

Stop the money (25 to 40 minutes)

- ☐ Bank or payment provider called and told in writing
- ☐ Affected customers told to contact their own bank
- ☐ Passwords reset (code generator, booking platform, email, payment dashboard)
- ☐ Multi-factor authentication confirmed

Report (40 to 55 minutes)

- ☐ Police or national fraud service
- ☐ Hosting provider or domain registrar of the fake page
- ☐ Payment provider (written)
- ☐ Data-protection authority, if a personal data breach of our systems is likely (decision recorded)

Tell (55 to 60 minutes)

- ☐ Notice displayed at the venue
- ☐ Notice posted online or sent to bookings
- ☐ Staff briefed

Review (within a week)

Question	Answer
How did it happen?	
How was it found?	
What would have found it sooner?	
What do we change?	
Who does it, and by when?	

APPENDIX F

Questions for a QR Code Provider

Ask these before you rely on a service to generate or host dynamic codes. Keep the written answers.

Question	Answer	Concern?
Who owns the short address the code points through?		
Can we use our own domain?		
What happens to our printed codes if we cancel or the service closes?		
Is multi-factor authentication available for the account?		
Can we limit administrators and see a log of changes?		
Are we told if the destination of a code is changed?		
Does the service show adverts or interstitial pages?		
Where is scan data stored, and who can see it?		
Is there a written data-processing agreement?		
How do we get our data out?		

Red flags: no account security options; scans routed through advertising pages; unclear ownership of the short address; a code that expires after a trial.

Glossary

Dynamic QR code. A code that points to a short address, which forwards to a destination that can be changed later.

Static QR code. A code that contains the destination directly and cannot be changed after printing.

Quishing. Phishing that uses a QR code to carry the link.

Overlay. A sticker or print placed over a genuine QR code to replace it.

Phishing. A message or page designed to trick someone into giving away information or money.

Preview address. The destination your phone shows after scanning, before opening it.

Typosquatting. Registering an address that is a small misspelling or variation of a real one.

Look-alike domain. An address designed to resemble a genuine one.

Multi-factor authentication (MFA). Signing in with more than a password, such as a code or a security key.

Client isolation. A router setting that stops devices on the same Wi-Fi network from talking to each other.

Guest network. A separate Wi-Fi network for visitors, kept apart from staff and payment systems.

Reconciliation. Comparing recorded sales with money actually received.

Private tell. A small feature on a printed code that only staff know about, used to confirm it is genuine.

Personal data breach. A security incident leading to the accidental or unlawful loss, alteration, disclosure of or access to personal data (GDPR Article 4).

A Note on GDPRGard.eu

GDPRGard publishes free tools, guides and articles to help small businesses understand data-protection duties in plain English, including how to check cookies and trackers, map data sharing, handle a data breach and respond to rights requests. Visit **gdprgard.eu** for current guidance, templates and updates to the topics in this book.

About the Author

Zirlandia Milkovic writes practical, plain-English guides on data protection, cyber-security, AI and building a business with confidence. She believes security is not a barrier to ambition but a foundation of trust, and that nobody should need a technical degree to protect their customers.

She is the author of a series of business guides, including *GDPR Made Simple for Women Founders*, and her work focuses on turning complex rules and fast-moving threats into simple steps, checklists and templates that busy people can actually use. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

Scan Before You Trust grew out of a simple observation: businesses print QR codes and trust them completely, and almost nobody checks them. If this guide helped you, an honest review where you bought it helps other readers find it.

Visit **gdprgard.eu** for free tools, articles and updates.

Notes and Sources

Research cut-off: 11 November 2026. Items marked (read) were opened directly; others were seen through search summaries or secondary coverage and should be checked against the original before you rely on them.

1. ESET, *ESET Threat Report H1 2026*, UK business landing page, section "Stop before you scan: QR code phishing on the rise": QR-code phishing at record levels, ESET telemetry averaging about 100,000 detections per month and peaking in April, QR codes in around 11% of detected phishing emails, most detections in the US, Spain and Mexico; report period December 2025 to May 2026 per the page's FAQ. The landing page was read; the full report sits behind a download form and was not read. Figures come from ESET's own detection systems and other sources (read, landing page only).
2. Microsoft Security Blog, "Email threat landscape: Q2 2026 trends and insights", 23 July 2026: QR-code phishing fell from 18.7 million in March to 17.4 million in April (-7%), then -38% in May and -22% in June, closing at 8.3 million, a level last seen in mid-2025; PDF attachments peaked at 79% of QR-code attacks in April and fell to 58% in June; email-embedded QR codes effectively disappeared in Q2. Microsoft publishes monthly figures for April and June only; the May figure in this book's chart is derived from the stated percentage changes (read).
3. Microsoft Security Blog, "Email threat landscape: Q1 2026 trends and insights", 30 April 2026: QR-code phishing rose from 7.6 million in January to 18.7 million in March (+146%); PDF attachments 65% to 70% of QR-code attacks; email-embedded QR codes rose 336% in March (read). The February figure in this book's chart is derived from the stated growth rates.
4. US Federal Bureau of Investigation, Internet Crime Complaint Center, Public Service Announcement I-011822-PSA, "Cybercriminals Tampering with QR Codes to Steal Victim Funds", 18 January 2022 (search summary and secondary coverage read; read the PSA at ic3.gov).
5. City of Austin, Texas, warnings about fraudulent QR codes on parking pay stations, January 2022: more than 900 stations checked, 29 with fraudulent codes (secondary coverage read, including Bruce Schneier's blog; check the City's notice).
6. UK National Cyber Security Centre, blog post "QR codes: what's the real risk?": codes in places such as pubs and restaurants are probably safe to scan; codes in open spaces such as stations and car parks may be riskier; emails are a particular concern; use the phone's built-in scanner (search excerpts and secondary summaries read; read the NCSC post).

7. Regulation (EU) 2016/679 (GDPR), Articles 4(12), 33 and 34: definition of a personal data breach; notification to the supervisory authority without undue delay and, where feasible, within 72 hours; communication to affected individuals where the risk is high. The UK GDPR contains equivalent provisions (working knowledge; read the text).
8. Denso Wave, history of the QR code: invented in 1994 by Masahiro Hara and colleagues for tracking automotive parts (working knowledge; the company's own history page describes it).
9. European Payments Council, EPC QR code guidelines for SEPA credit transfers (working knowledge; read the current EPC guidelines). The Wi-Fi code text format described in Chapter 8 is a widely used convention supported by major phone cameras.

Not verified by the author: the exact current features, limits and menu names of any QR generator, router or payment product; how any particular payment provider allocates losses from a diverted code; city-level warnings beyond those listed; and the complete content of the ESET full report. Parking-meter sticker cases are well documented; documented restaurant-table cases are thinner, and the book says so. The stories of Nadia's café, Kofi, Hotel Marina Verde and Lumen Night Market are fictional.